EXP - 12

Implementing Security Features and Governance / Administration Practices in Zoho Creator

Aim

To study and implement security controls, access governance and administration practices in a Zoho Creator application.

Introduction

Business applications hold sensitive data such as customer records, financial details and employee information. Security ensures only the right people see or change the right data. Governance is the set of policies, roles and monitoring practices that keep the platform controlled as it grows.

Core Security Concepts (CIA Triad)

- Confidentiality: only authorised users can view data.
- Integrity: data cannot be altered improperly.
- Availability: the application remains accessible to legitimate users.

Security Features in Zoho Creator

1. Authentication

- Users sign in with Zoho accounts or supported identity providers.
- Two-factor authentication (2FA/MFA) adds a second verification step.
- Single Sign-On (SSO) through SAML / identity providers for organisations.
- Password policies and session controls.

2. Authorisation: Users, Roles and Profiles

- Users: people invited to the application.

- Profiles: define what a user can do (for example create, view, edit, delete, access to pages/reports/forms). Typical built-in levels include administrator-type and standard user-type profiles; custom profiles can be created.
- Roles: define the data-visibility hierarchy (for example a manager can see records of their reportees).
- Permissions can be set at the level of form, report, page and individual field.

3. Data-Level Security

- Record-level filtering: users see only records that match criteria (e.g., own records, own department).
- Field-level permissions: hide or make read-only sensitive fields (e.g., salary, phone).
- Sharing settings: control which forms/reports/pages are shared with which users or publicly.
- Public vs. private publishing: publicly published forms/reports should be limited and protected (CAPTCHA, restricted fields).

4. Platform-Level Protections

- Data encryption in transit (HTTPS/TLS) and at rest.
- IP restrictions to allow access only from specific networks.
- Domain/organisation level controls.
- Compliance certifications and regional data centres supporting regulations such as GDPR.

Governance and Administration Practices

- Principle of least privilege: give users only the access needed for their job.
- Role-based access control (RBAC): assign access by role, not by individual.
- Audit trail / activity logs: track who created, changed or deleted records and when.
- Change management: development in a separate environment, approval before deployment.
- User lifecycle management: onboard, modify and promptly deactivate users who leave.

- Data governance: naming conventions, data ownership, retention and backup rules.
- API governance: protect OAuth connections, rotate credentials, restrict API scopes.
- Regular reviews: periodic access reviews and permission audits.
- Documentation: maintain app documentation, data dictionaries and admin runbooks.

Typical Implementation Steps (Practical Outline)

1. Create profiles (e.g., Admin, Manager, Staff).
2. Define roles representing the organisation hierarchy.
3. Invite users and assign profile + role.
4. Configure form/report/page permissions per profile.
5. Apply field-level restrictions for sensitive fields.
6. Set record-level criteria (e.g., Staff sees only own records).
7. Enable 2FA and, if needed, IP restrictions.
8. Test by logging in as different users.
9. Review audit/activity logs.

Risks if Governance is Weak

- Data leakage through over-shared reports.
- Unauthorised edits or deletions.
- Shadow IT: unmanaged apps built without oversight.
- Compliance violations and loss of trust.

Conclusion

Zoho Creator provides layered security: authentication, role and profile based authorisation, field and record-level control, and administrative monitoring. Combined with good governance practices, it allows organisations to scale low-code development safely.